

Introduction to Cryptography — Course Questions

Model Answers

1) What is cryptography, and what is its main purpose in daily digital life?

Cryptography is the science of securing information and communication using mathematical techniques, so that only authorised parties can read or use it. The name comes from the Greek for "hidden writing."

In **daily digital life**, its main purpose is to protect the **confidentiality, integrity, and authenticity** of our data in an open, untrusted environment like the internet. You rely on it constantly, usually without noticing:

- **HTTPS** secures websites (online banking, shopping, logins).
- **Messaging apps** (WhatsApp, Signal) use end-to-end encryption so only you and the recipient can read messages.
- **Passwords** are stored as hashes, not plaintext.
- **Wi-Fi (WPA), bank cards/PINs, and digital signatures** all depend on cryptography.

In short, cryptography is what makes it safe to send private and valuable information across networks we don't control.

2) What are the core principles of cryptography?

These are the four **security services** cryptography provides:

1. **Confidentiality** — keeping information secret from unauthorised parties (via encryption).
2. **Integrity** — ensuring data has not been altered or tampered with (via hash functions and MACs).
3. **Authentication** — verifying the identity of a user or the origin of a message.
4. **Non-repudiation** — preventing a sender from later denying that they sent a message (via digital signatures).

(Access control and availability are sometimes added as supporting goals.)

3) Explain in detail Encryption and Decryption. Give an example.

Encryption is the process of converting readable data (**plaintext**) into an unreadable form (**ciphertext**) using an algorithm and a **key**. **Decryption** is the reverse process — converting ciphertext back into the original plaintext using the correct key.

```
Plaintext --[ Encrypt with key ]--> Ciphertext
Ciphertext --[ Decrypt with key ]--> Plaintext
```

The purpose is **confidentiality**: even if an attacker intercepts the ciphertext, they cannot read it without the key.

Example (Caesar cipher, shift of 3): Each letter is shifted three places forward in the alphabet.

- Plaintext: **HELLO**
- Encryption (shift +3): H→K, E→H, L→O, L→O, O→R → Ciphertext: **KHOOR**
- Decryption (shift -3): **KHOOR** → **HELLO**

Here the "algorithm" is *shift the letters*, and the "key" is the *number 3*. Modern algorithms like **AES** work on the same principle but with far more complex mathematics on bits.

4) What is a "key" in cryptography, and why must it be kept secret in symmetric systems?

A **key** is a secret value (a string of bits) that controls the encryption and decryption process. The same algorithm with different keys produces different ciphertext, and only the correct key can reverse the encryption.

In a **symmetric system**, the **same key** is used to both encrypt *and* decrypt. Therefore, anyone who obtains that key can decrypt every message protected by it. If the key leaks, all confidentiality is lost. This is why it must be kept strictly secret and shared only through a secure channel.

This reflects **Kerckhoffs's principle**: the security of a system should depend only on the secrecy of the **key**, not the secrecy of the algorithm (which can be public). The key is the single most important secret in the system.

5) Explain "data integrity" and name one cryptographic tool used to verify it.

Data integrity is the assurance that data has **not been altered, corrupted, or tampered with** —

whether accidentally (transmission errors) or maliciously (an attacker) — between the time it was created/sent and the time it is received/used. Integrity does *not* keep data secret; it guarantees the data is unchanged and trustworthy.

Cryptographic tool: a cryptographic hash function (e.g., **SHA-256**). The sender computes a hash (a fixed-length "fingerprint") of the data and shares it. The receiver re-computes the hash of the received data and compares: if the two hashes match, the data is intact; if even one bit changed, the hash will differ. *(MACs/HMACs and digital signatures provide integrity plus authentication.)*

6) What does "brute-force attack" mean in simple terms?

A **brute-force attack** means simply **trying every possible key or password, one after another, until the correct one is found**. It uses no cleverness — just exhaustive guessing, usually automated at high speed.

A good analogy is a thief trying every possible combination on a padlock until it opens. Its success depends entirely on the **size of the key space**: a short or simple key can be cracked quickly, but a long key (e.g., a 256-bit AES key) has so many possible combinations that trying them all would take longer than the age of the universe — making brute force infeasible. This is why **longer keys and strong passwords** are important.

7) What are the differences between hashing and encryption?

	Hashing	Encryption
Direction	One-way (irreversible)	Two-way (reversible)
Key	No key needed (keyless), or keyed for HMAC	Always uses a key
Output	Fixed-length digest	Length related to input
Goal	Integrity , password storage, fingerprints	Confidentiality
Can you get the original back?	No — you cannot "un-hash"	Yes — decrypt with the key
Examples	SHA-256, SHA-512, SHA-3	AES, RSA, DES

Key idea: Encryption *protects secrecy* and can be undone with a key; hashing *verifies integrity* and is meant to be impossible to reverse.

8) What is the difference between an "active attack" and a "passive attack"?

- **Passive attack:** The attacker only **observes or eavesdrops** on the communication without changing it. The goal is to obtain information. Examples: **sniffing/wiretapping** to read messages, and **traffic analysis** (studying patterns even if content is encrypted). Passive attacks are **hard to detect** (they leave no trace) but are **prevented** by encryption, which makes intercepted data unreadable.
- **Active attack:** The attacker **modifies, injects, deletes, replays, or fabricates** data, or disrupts the service. The goal is to alter the system or impersonate. Examples: **man-in-the-middle, message modification, masquerade/impersonation, replay attacks, and denial-of-service**. Active attacks **can be detected** (they change the data) but are harder to fully prevent; they are countered with **authentication and integrity** mechanisms (MACs, digital signatures).

Summary: Passive = *listening only* (hard to detect, prevent with encryption); Active = *tampering/interfering* (detectable, defend with authentication and integrity checks).

9) Explain the difference between plaintext and ciphertext.

- **Plaintext** is the **original, readable** message or data *before* encryption — what you actually want to communicate (e.g., the text **HELLO**).
- **Ciphertext** is the **scrambled, unreadable** output produced *after* encrypting the plaintext (e.g., **KHOOR**). Without the correct key, it looks like meaningless data.

Encryption turns plaintext into ciphertext; decryption turns ciphertext back into plaintext.

10) What is a "cipher"? Give an example of a classical cipher.

A **cipher** is an **algorithm (a defined method)** for performing encryption and decryption — the set of rules that transforms plaintext into ciphertext and back, controlled by a key.

Classical cipher example — the Caesar cipher: a *substitution* cipher that replaces each letter with one a fixed number of positions further along the alphabet. With a shift of 3, **A→D**, **B→E**, and **HELLO→KHOOR**. Other classical examples include the **Vigenère cipher** (using a keyword) and **transposition ciphers** (which rearrange the order of letters rather than substituting them).

11) Why is it insecure to reuse the same password everywhere, and how does cryptography help?

Why it's insecure: If you reuse one password and *any* single website is breached and its password database is leaked, attackers will take that password and try it on all your other accounts (email, banking, social media). This automated technique is called **credential stuffing** — one breach then compromises *everything*. The weakest site you ever signed up to becomes the weak link for all your accounts.

How cryptography helps:

- **Hashing + salting:** Reputable sites never store passwords in plaintext; they store **salted hashes**, so even if the database is stolen, the actual passwords are hard to recover.
- **Password managers:** These generate a **unique, strong, random password for every account** and store them in an **encrypted** vault — so you only remember one master password while every account stays distinct.
- **Multi-factor authentication and cryptographic tokens** add a second layer so a stolen password alone is not enough.

Together, cryptography both protects stored passwords and makes it practical to use a different strong password for every account.

12) What is the main purpose of a "digital certificate" when you visit a secure (HTTPS) website?

A **digital certificate** (an **X.509 certificate**) is an electronic document, issued and signed by a trusted **Certificate Authority (CA)**, that binds a website's **identity** (its domain name) to its **public key**.

Its main purposes when you visit an HTTPS site are:

1. **Authentication / trust** — it proves you are connecting to the **genuine website** and not an impostor, protecting you from impersonation and man-in-the-middle attacks. Your browser checks that the certificate was signed by a trusted CA and matches the site.
2. **Providing the public key** — it supplies the site's public key, which your browser uses to **securely establish an encrypted TLS session** (typically exchanging a symmetric session key).

In short, the certificate answers "**is this site really who it claims to be?**" and supplies the key needed to set up the encrypted connection (the padlock icon).

13) What is the main difference between symmetric and asymmetric encryption regarding how they use keys?

- **Symmetric encryption** uses **one single shared secret key** for *both* encryption and decryption. Both sender and receiver must have the same key and keep it secret. (e.g., AES)
- **Asymmetric encryption** uses a **pair of mathematically related keys** — a **public key** and a **private key**. One key encrypts and the *other* decrypts: typically the **public key encrypts** and only the matching **private key decrypts**. The public key can be shared openly, while the private key is kept secret. (e.g., RSA)

Main difference: symmetric = *one* secret key shared by both parties; asymmetric = *two* keys per person (a public one and a private one), removing the need to share a secret key in advance.

14) If Alice wants to send a secret message to Bob, which key should she use — Bob's public key or Bob's private key? Explain.

Alice should encrypt the message with **Bob's public key**.

Why: In asymmetric cryptography, anything encrypted with Bob's **public key** can only be decrypted with Bob's **private key** — and Bob is the only person who holds that private key. So only Bob can read the message, which guarantees **confidentiality**.

She must *not* use Bob's **private key** — Alice doesn't have it (it's Bob's secret), and even conceptually it wouldn't keep the message secret, because anything "locked" with a private key can be opened with the matching public key, which everyone knows. (Encrypting with a *private* key is what's done for **digital signatures**, not for secrecy.) Using her own keys also wouldn't work, since Bob couldn't decrypt it.

Rule of thumb: to send someone a secret, encrypt with **the recipient's public key**.

15) What is "steganography," and how does it differ from traditional cryptography?

Steganography is the practice of **hiding the very existence of a message** by concealing it inside ordinary-looking data — such as embedding secret text within the pixels of an image, an audio file, or a video — so that an observer does not even realise a hidden message is present.

How it differs from cryptography:

	Cryptography	Steganography
What it hides	The meaning/content of the message	The existence of the message
Is the message visible?	Yes, but it appears as unreadable ciphertext	No — it looks like an ordinary file
Goal	Make the message unreadable to outsiders	Make the message undetectable

In short: **cryptography scrambles a message so it cannot be *understood*; steganography hides a message so it cannot be *found*.** A classic example is altering the least-significant bits of an image's pixels to embed hidden text invisibly. The two techniques can be combined — encrypting a message *and then* hiding it — for even stronger protection.